# Strong Authentication - Adaptive Authentication

## Introduction:

Adaptive authentication is a secure and flexible form of authentication. It enables adjusting the authentication factors based on the risk probability associated with the access request. This enables ensuring security without impacting usability at the time of authentication thereby providing enhanced user experience.

WSO2 Identity Server allows you to configure appropriate authentication factors via a script. The authentication script editor of the WSO2 Identity Server Management Console enables configuring the authentication script and supports a set of **predefined templates to** easily set up the authentication logic.

These are the adaptive authentication scenarios supported in WSO2 Identity Server which can be used to configure the adaptive authentication.

- User role based
- User store based
- Login attempts based
- User group based
- User device based
- IP address based

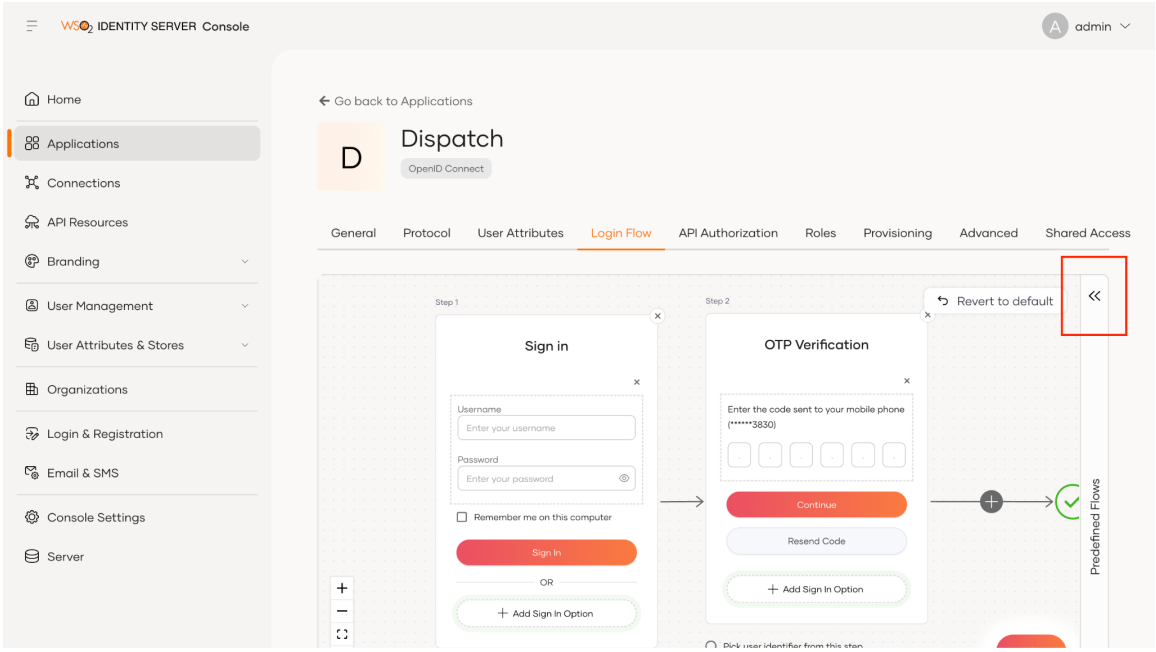
This tutorial guides you to configure the following adaptive authentication scenarios in WSO2 Identity Server using sample applications.

CC BY 4.0

- User role based
- User device based
- IP address based

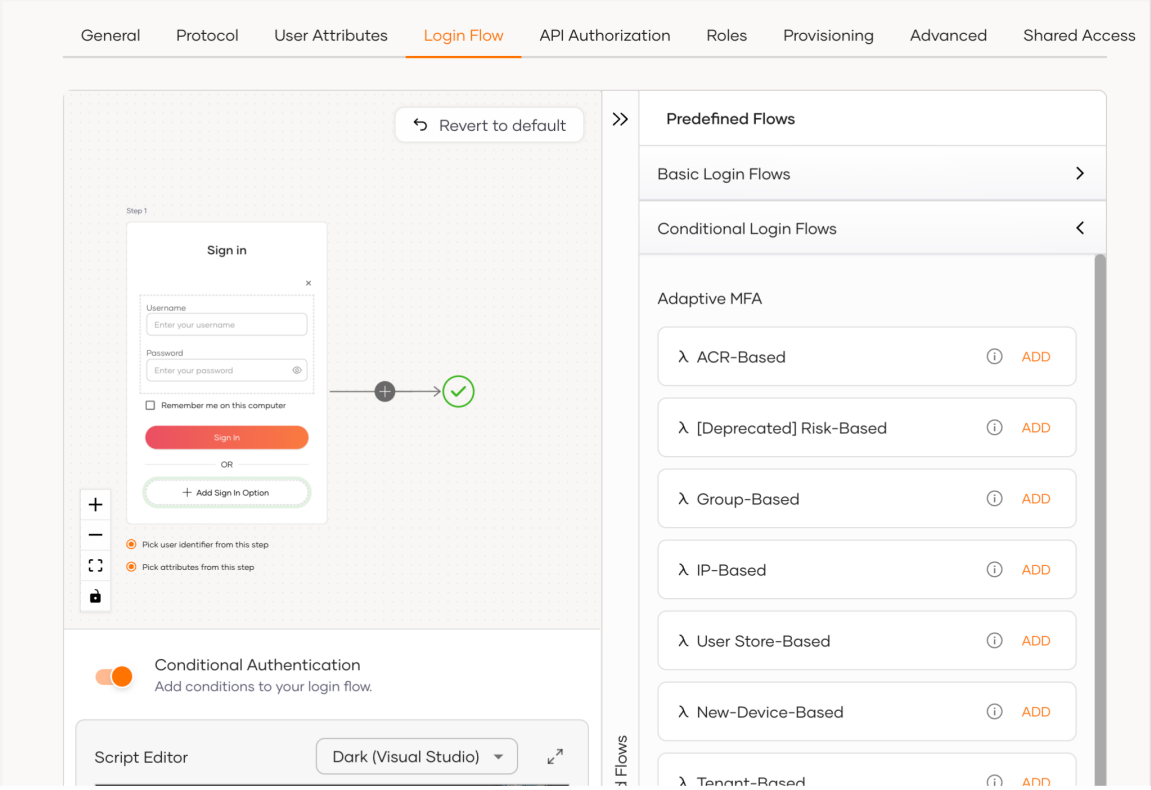
# Configure Application with Adaptive Authentication script

1. In the WSO2 Identity Server **Console,** from the menu click **Applications.**
2. Click on the configured **Dispatch** Application**.**
3. Goto to the **Login Flow** tab.
4. Toggle the **Conditional Authentication** button.
    - In WSO2 Identity Server 7.3.0, Conditional Authentication is available by default, so no extra configuration is needed.
5. Click on the **Predefined Flows.**




6. Collapse the **Basic Login Flow** and Expand **Conditional Login Flows**.

CC BY 4.0


General
Protocol
User Attributes
Login Flow
API Authorization
Roles
Provisioning
Advanced
Shared Access
Revert to default
Step 1
Sign in
Username
Enter your username
Password
Enter your password
Remember me on this computer
Sign In
OR
Add Sign In Option
Pick user identifier from this step
Pick attributes from this step
Conditional Authentication
Add conditions to your login flow.
Script Editor
Dark (Visual Studio)
Predefined Flows
Basic Login Flows
Conditional Login Flows
Adaptive MFA
λ ACR-Based
ADD
λ [Deprecated] Risk-Based
ADD
λ Group-Based
ADD
λ IP-Based
ADD
λ User Store-Based
ADD
λ New-Device-Based
ADD

CC BY 4.0

# User Role-Based Adaptive Authentication

## Introduction:

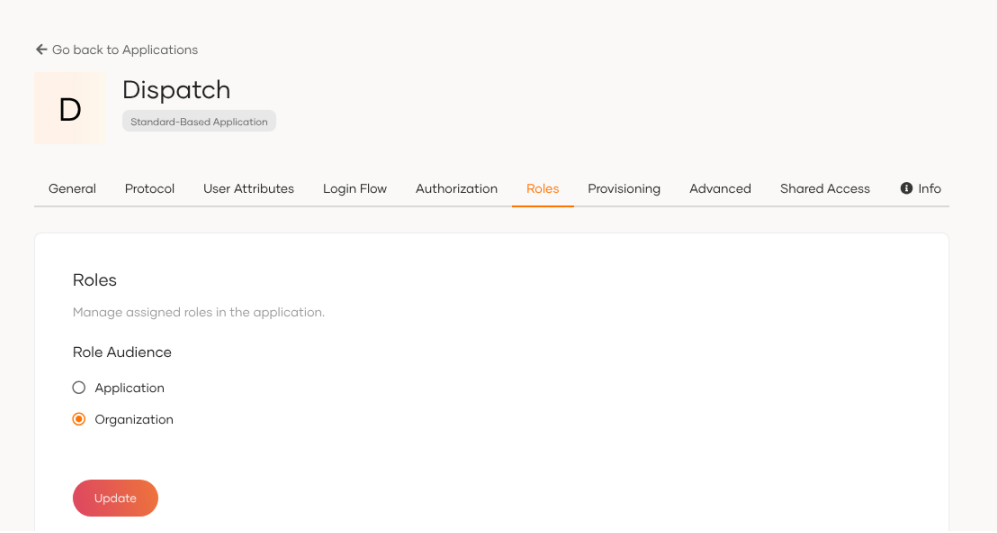
In this scenario we are going to create two users:

1. Arya: has the **admin** and **manager** roles.
2. John: has the **director** role.

Users who have the **admin** or **manager** role must do two-factor authentication (2FA) with Email OTP. Users without these roles log in with only their username and password.

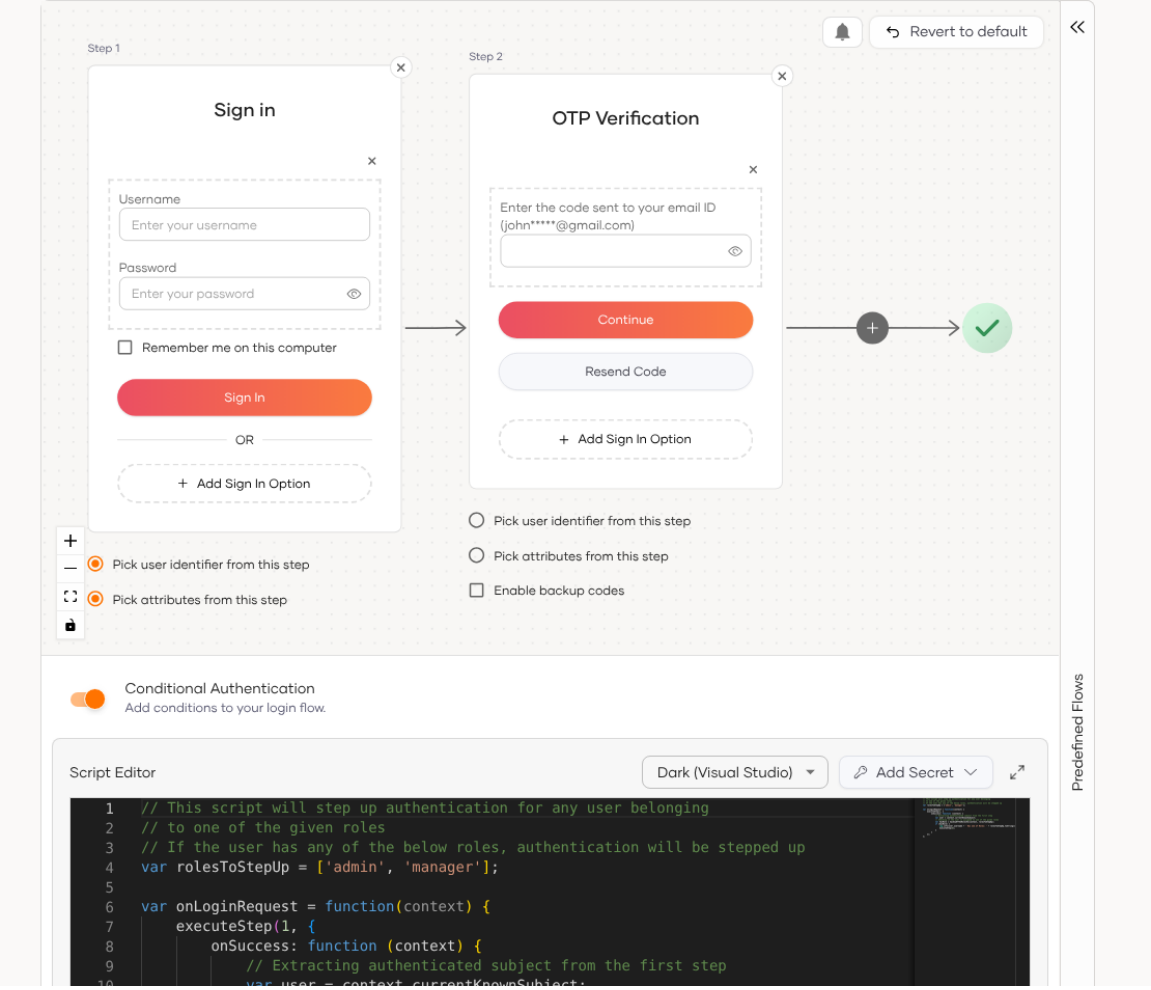
## Setting up:

1. Set the role audience of the application to Organization, so that the organization roles (admin, manager, director) are evaluated:
    a. Open the **Dispatch** application and go to the **Roles** tab.
    b. Under **Role Audience**, select **Organization**, tick the confirmation and click **Confirm**, then click **Update**.




CC BY 4.0

2. Go to the **Login Flow** tab and locate the Authentication Script Editor configured in the Configure Application with Adaptive Authentication script section.
3. Then click **Role-Based > ADD** and click **Confirm**.
4. As you can see, the script steps up authentication for the roles in `rolesToStepUp`: `admin` and `manager`.
5. The template adds **TOTP** and **Passkey** to Step 2. Change Step 2 to Email OTP. Do not click **Revert to default**: it also removes the conditional authentication script.
    a. Keep **Username & Password** in Step 1.
    b. In Step 2, hover over **TOTP** and click the **x** to remove it. Do the same for **Passkey**.
    c. In Step 2, click **+ Add Sign In Option**, select **Email OTP** and click **Add**.



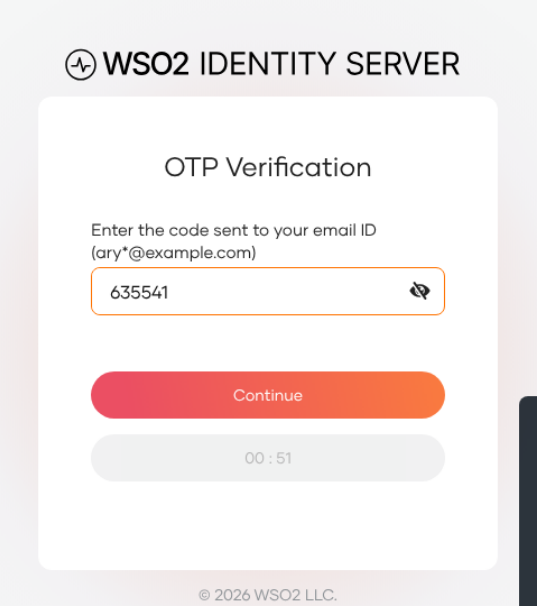

CC BY 4.0

6. Click **Update.**
7. Create the users Arya and John with proper roles as described in Lab 01-02 (User, Group and Role Management). Because the role audience is Organization, create **admin**, **manager** and **director** as organization roles (admin already exists). Add an email address for each user so that they can receive the OTP (the email server is configured in Lab 03, User Account Management).

   **Note:** the script function `hasAnyOfTheRolesV2` also evaluates indirect roles. For example, if a role is assigned to a group and the user is a member of that group, the user has that role too and is also asked for the Email OTP.

## Try it:

1. Access http://localhost:8080/pickup-dispatch/
2. Login as **Arya.**
3. After the password, the **OTP Verification** page appears. Enter the code sent to Arya's email address and click **Continue**.




4. Login as **John.**

CC BY 4.0

5. Only step 1 is displayed: John is logged in after entering his password, because he has neither the admin nor the manager role.

# User Device Based Adaptive Authentication

## Introduction:

In this scenario, we are going to create a user

1. Snow: who can access Pickup Dispatch

When Snow tries to login for the first time he will undergo 2FA and then the next time he can log in in a single step. This is done through cookies and their validation period is 2 years by default but can be changed. So when it expires again he has to undergo a 2FA.

## Setting up:

1. Locate the **Authentication Script Editor** configured at Add Authentication script.
2. Then click **New-Device-Based -> ADD.**
3. In the **Authentication Step Configuration**, keep **Username & Password** in Step 1. In Step 2, remove **TOTP** (added by the template) and add **Email OTP**.
4. Click **Update.**

## Try it:

1. Access http://localhost:8080/pickup-dispatch/.
2. Login as **'Snow'.**
3. Both the configured steps will be displayed.
4. Logout and retry within the same browser.
5. Only step 1 will be displayed.
6. Now try with a different browser.
7. Both the configured steps will be displayed and once you login you will receive an email with the login timestamp.

CC BY 4.0

# Login from a new device

Hi,

A login from a new device has been detected for your account **Tommy**, at **Fri, 29 Mar 2024 10:24:41 GMT**.

If this was not you, please contact {{organization.support.mail}} immediately.

WSO2 Identity Server

You received this email because you have an account in the organization **carbon.super**. If you encounter any issues, you may contact us at {{organization.support.mail}}.

This mail was sent by WSO2 LLC. 3080 Olcott St., Suite C220, Santa Clara, CA 95054, USA

CC BY 4.0

# IP-Based Adaptive Authentication

## Introduction:

In this scenario, we are going to create a user

1. Daenerys: who can access Pickup Dispatch

We will add our IP address into the recognized address range and login in one step. Then we will have a different address range which does not have our IP address. Now when we log in we have to go through 2FA.

## Setting up:

1. Locate the **Authentication Script Editor** configured at Add Authentication script.
2. Then click **IP-Based -> ADD.**
3. Add this range '**127.0.0.0/16**' to the **var corpNetwork** (make sure your IP address range is captured here).
4. Click **Update**.
5. In the **Authentication Step Configuration**, keep **Username & Password** in Step 1. In Step 2, remove **TOTP** (added by the template) and add **Email OTP**.
6. Click **Update.**
7. Now create the users Daenerys

## Try it:

1. In the browser go to http://localhost:8080/pickup-dispatch/
2. Now try to login using **Daenerys's credential**
3. You will be logged in one step
4. Now again follow the steps to configure IS but now don't add your range in **step 3**. (**remove the address range corresponding to you**)
5. Again try to login using **Daenerys's credential**
6. This time after basic login, you will be redirected to another login page

CC BY 4.0

7. Enter the OTP sent to the user's email address and click **Continue**.
8. Now you have login using 2 steps.

CC BY 4.0